Privileged Access Workstation (PAW) for Cloud Administration

Implementation Solution Guide

Version 1.0.0 · 2026-07-11

Contents

Executive Summary — Privileged Access Workstation (PAW) for Cloud Administration 5

What you get . . . 5

What this delivers . . . 5

The standard deployment model . . . 5

Outcome . . . 6

1. Solution Overview — Privileged Access Workstation (PAW) for Cloud Administration 6

What a PAW is . . . 6

How it works . . . 6

What you can control . . . 7

Benefits . . . 7

Limitations (be honest with buyers) . . . 7

Auth / connections used . . . 7

The standard deployment model . . . 8

2. Requirements Guide — Privileged Access Workstation (PAW) for Cloud Administration 8

2.1 Microsoft Intune (device management) . . . 8

2.2 Entra ID P2 (PIM and device-filter enforcement) . . . 8

2.3 Dedicated PAW hardware (or clean, dedicated devices) . . . 8

2.4 Admin accounts separated from user accounts . . . 9

2.5 PIM eligibility for the operated roles . . . 9

2.6 Break-glass exclusion group . . . 9

2.7 A device-marking method for the CA device filter . . . 9

2.8 Pilot scope (admins and devices) . . . 9

Checklist . . . 10

Global Requirements — Entra ID Solutions (category-level) 10

G1. Microsoft Entra ID tenant . . . 10

G2. Entra ID licensing (P1, P2 where noted) . . . 10

G3. Administrative roles . . . 10

G4. Break-glass (emergency access) accounts . . . 10

G5. Healthy on-premises Active Directory . . . 11

G6. An Entra Connect host server . . . 11

G7. UPN / domain hygiene . . . 11

G8. Network access to Microsoft cloud endpoints . . . 11

3. Implementation Guide — Privileged Access Workstation (PAW) for Cloud Administration 11

Naming convention (create/verify these exact names) . . . 12

Step 1 — Assess and record the starting state . . . 12

Step 2 — Create the pilot groups . . . 12
Step 3 — Enrol and build the hardened PAW in Intune . . . 12
Step 4 — Define what a PAW is (compliance policy) . . . 13
Step 5 — Mark the PAW devices for the device filter . . . 13
Step 6 — Create the Conditional Access device-filter policy (Report-only) . . . 13
Step 7 — Wire PIM activation from the PAW . . . 14
Step 8 — Pilot and read the report-only results . . . 14
Step 9 — Flip to enforcement (staged) . . . 14
Step 10 — Expand to production . . . 14
5. Testing Guide — Privileged Access Workstation (PAW) for Cloud Administration 15
Test 1 — PAW is hardened and compliant . . . 15
Test 2 — Device marker is set only on PAWs . . . 15
Test 3 — Enforcement policy exists, report-only, break-glass excluded . . . 15
Test 4 — Privileged sign-in from the PAW would succeed . . . 15
Test 5 — Privileged sign-in from a non-PAW would be blocked . . . 15
Test 6 — PIM activation works from the PAW . . . 15
Test 7 — Break-glass path is never blocked . . . 16
Test 8 — Non-PAW privileged access is visible in reporting . . . 16
Test 9 — Enforcement matches the report-only prediction . . . 16
Pass/fail gate . . . 16
6. Troubleshooting Guide — Privileged Access Workstation (PAW) for Cloud Administration 16
A. PAW not recognised by the device filter . . . 16
B. Compliance / hardening problems . . . 17
C. Break-glass / lockout risk . . . 17
D. Conditional Access enforcement issues . . . 17
E. PIM activation from the PAW . . . 18
F. Licensing / feature not visible . . . 18
G. Diagnostics quick reference . . . 18
H. When to escalate . . . 18
7. Best Practices — Privileged Access Workstation (PAW) for Cloud Administration 19
Where to go next (adjacent catalog areas) . . . 19
8. Deliverables Summary — Privileged Access Workstation (PAW) for Cloud Administration 20
Documentation . . . 20
PowerShell scripts (and KQL) . . . 20
What the buyer receives . . . 21
Outcome . . . 21

Appendix A — PowerShell Scripts 22

Executive Summary — Privileged Access Workstation (PAW) for Cloud Administration

White-label · Entra ID Solutions

The fastest way to lose a tenant is to let an administrator read email and browse the web on the same device they use to administer the cloud. One phishing link or one drive-by on that device, and the attacker is one token-theft away from Global Administrator. A Privileged Access Workstation (PAW) breaks that chain: administration happens only from a dedicated, hardened, Intune-managed Windows device that cannot read email or browse the open web — and Conditional Access refuses privileged sign-ins from anything else.

This solution delivers the whole PAW model end to end. It builds the hardened device (security baselines, Attack Surface Reduction, application control, and web/email isolation), it marks those devices so Conditional Access can recognise them, it enforces via **Conditional Access device filters** that privileged roles can sign in **only** from a compliant PAW, and it integrates **Privileged Identity Management (PIM)** so admin rights are activated just-in-time *from the clean device*. Every enforcement step is piloted before it blocks anyone, and break-glass emergency accounts are kept safe throughout.

This is a complete, deploy-it-today package written for an administrator with no prior PAW experience. It is the device-and-enforcement layer of a privileged-access program; it references — and does not re-teach — PIM, the Conditional Access baseline, and Intune endpoint security, which it builds on.

What you get

- A plain-language Solution Overview of the PAW model: what a PAW is, how hardening, isolation, device filters, and PIM fit together, and the clean-source principle behind it.
- A Requirements Guide with verify / implement-if-missing for every solution-specific prerequisite (Intune, Entra ID P2 for PIM/device filters — flagged to verify).
- An Implementation Guide of precise, ordered steps to build the PAW, mark it, enforce with Conditional Access device filters (report-only first), and wire PIM — with break-glass kept safe.
- Five PowerShell scripts (Microsoft Graph / Az) plus KQL for discovery, pilot validation, a privileged-access-from-non-PAW report, a safe Conditional Access state flip, and PAW device tagging.
- Testing and Troubleshooting guides for a confident rollout.

What this delivers

A clean administrative plane: admins operate from hardened, isolated, Intune-managed PAWs; Conditional Access device filters make privileged sign-in impossible from a general-purpose or compromised device; and PIM grants admin rights just-in-time, only from the PAW. Break-glass emergency accounts are excluded from the enforcement policy so a device-filter mistake can never lock every administrator out.

The standard deployment model

Assess -> Configure -> Pilot -> Validate -> Expand.

Outcome

Administrators working from clean, isolated, hardened workstations — with privileged access impossible from a general-purpose or compromised device — proven on a pilot before you enforce.

1. Solution Overview — Privileged Access Workstation (PAW) for Cloud Administration

What a PAW is

A Privileged Access Workstation (PAW) is a dedicated, hardened, Intune-managed Windows device used **only** for administrative work. It has no general-purpose email client and no open web browsing; it runs a locked-down configuration (security baselines, Attack Surface Reduction, application control), and it is the *only* device from which privileged roles are allowed to sign in. The principle is **clean source**: a high-value credential (a cloud admin role) must only be used from an equally high-trust device — never from the same laptop that reads email and browses the web.

This solution assembles the PAW model from Microsoft capabilities you may already license: **Microsoft Intune** builds and enforces the hardened device; **Conditional Access device filters** require a compliant PAW for privileged sign-ins; and **Privileged Identity Management (PIM)** grants the admin role just-in-time from that clean device. It is the device-and-enforcement layer of a privileged-access program — it complements, and does not replace, PIM, the Conditional Access baseline, and Intune endpoint security, each of which has its own solution.

How it works

1. **Build the PAW.** Intune enrols a dedicated Windows device and applies a hardened configuration: a security baseline, Attack Surface Reduction (ASR) rules, application control (allow-listing so only approved admin tooling runs), and device restrictions that remove or block general-purpose email and open web browsing. The device is standard-user by default — no local admin for the day-to-day operator.

2. **Prove the device is a PAW.** A device compliance policy defines what "a healthy PAW" means, and the device is **marked** (a device category, a device group, or an extension attribute) so Conditional Access can recognise it. Only marked, compliant devices count as PAWs.

3. **Enforce with Conditional Access device filters.** A Conditional Access policy targets privileged sign-ins (by directory role or by the sensitive admin apps such as the Microsoft Azure Management and Entra/Graph endpoints) and, using a **device filter**, grants access only when the device matches the PAW marker AND is compliant. Anything else is blocked. This is piloted **report-only first**.

4. **Grant admin just-in-time with PIM.** Admin roles are held **eligible**, not standing. The operator signs in from the PAW and activates the role in PIM for a limited window with approval and MFA — so privilege is time-bound and only ever exercised from the clean device.

5. **Break-glass stays safe.** Break-glass emergency accounts are excluded from the device-filter enforcement policy, so a marking or compliance mistake can never lock every administrator out of the tenant.

6. **Operate and monitor.** Sign-in and Intune logs show any attempt to use privileged access from a non-PAW device; the included report/hunt tooling surfaces those attempts so you can close gaps.

What you can control

• The PAW hardened configuration: which security baseline, which ASR rules, the application-control (allow-list) policy, and the web/email isolation restrictions.

• The compliance definition of a PAW and how devices are marked (category / group / extension attribute).

• The Conditional Access device-filter policy: which roles/apps it protects, the device-filter rule, report-only vs enforced state, and break-glass exclusions.

• The PIM eligibility and activation policy for the roles operated from the PAW (approval, MFA, duration).

• The pilot scope and the staged expansion to all privileged operators.

Benefits

• Clean source — high-value admin credentials are only ever used from a high-trust, isolated device.

• Blast-radius reduction — a compromised general-purpose laptop cannot reach privileged access at all.

• Token-theft resistance — no email/web on the PAW removes the most common initial-access and token-theft paths for admin sessions.

• Enforced, not advisory — Conditional Access device filters make "use a PAW" a hard control, not a policy document.

• Just-in-time — PIM keeps privilege time-bound and activated only from the clean device.

Limitations (be honest with buyers)

• Requires **Microsoft Intune** to build and enforce the device, and **Entra ID P2** for PIM and for the risk-aware parts of Conditional Access. *Verify current licensing availability in your tenant.*

• A PAW is a **dedicated** device — admins need a separate device (or a well-separated profile/VDI approach) for general productivity. Plan for that operational cost.

• Application control (allow-listing) and web/email isolation change the admin's daily experience; they need a short tuning period on the pilot before expansion.

• This governs the device and the enforcement; it does not replace PIM governance, a Conditional Access baseline, or endpoint protection — it depends on them.

Auth / connections used

• Interactive administration in the Microsoft Intune admin center (`https://intune.microsoft.com`) and the Entra admin center (`https://entra.microsoft.com`).

• The included scripts use the **Microsoft Graph PowerShell SDK** (read-only scopes for discovery/validation/report; a scoped read-write scope only for the gated Conditional Access state change and the device-tagging script) and optionally **Az** / a Log Analytics workspace for KQL hunting of privileged sign-ins from non-PAW devices.

The standard deployment model

> *Assess admins, roles, and current devices -> Configure the hardened PAW (baseline, ASR, app control, isolation), the compliance/marking, the Conditional Access device-filter policy in report-only, and PIM eligibility -> Pilot on a small set of admins/devices -> Validate report-only results and flip the device-filter policy to enforce -> Expand to all privileged operators. Break-glass stays excluded throughout. pattern: Assess -> Configure -> Pilot -> Validate -> Expand.*

2. Requirements Guide — Privileged Access Workstation (PAW) for Cloud Administration

Verify every requirement before configuring. Each entry: Description · Why · Verify · Implement-if-missing. Category-wide prerequisites (tenant, base licensing, admin roles, break-glass accounts, network) are in `global-requirements-entra-id-solutions.md` — do not repeat them here; confirm them first.

2.1 Microsoft Intune (device management)

Description: An active Microsoft Intune service with Windows device management enabled. Why: Intune builds and enforces the hardened PAW — baseline, ASR, application control, restrictions, and the compliance policy that defines a PAW. Verify: `https://intune.microsoft.com` -> `Devices`; confirm Windows enrolment is configured; run `ENTPAW-Discovery.ps1`. Implement: License Intune (bundled in M365 E3/E5, EMS) and configure Windows enrolment (Automatic enrolment / Autopilot). *Verify current licensing in your tenant.*

2.2 Entra ID P2 (PIM and device-filter enforcement)

Description: Microsoft Entra ID P2 for the administrators who will use the PAW. Why: PIM (just-in-time activation) requires P2; risk-aware and advanced Conditional Access require P2. Device filters themselves are a Conditional Access feature and require Conditional Access (P1+). Verify: M365 admin center -> `Billing -> Licenses`; confirm Entra ID P2 for the admin accounts; in Entra confirm `Identity governance -> PIM` is available. *Verify current licensing availability in your tenant.* Implement: Assign Entra ID P2 to the privileged operators, then run `ENTPAW-Discovery.ps1`.

2.3 Dedicated PAW hardware (or clean, dedicated devices)

Description: A physically or logically dedicated Windows device per privileged operator, used only for administration. Why: The clean-source principle requires the admin credential to be used only from a high-trust device; a shared or general-purpose device defeats the control. Verify: Confirm each pilot admin has a dedicated device that is not their daily productivity machine. Implement: Provision dedicated hardware (preferred) or a well-isolated dedicated device/VDI for each admin; do not dual-purpose it for email/web.

2.4 Admin accounts separated from user accounts

Description: Administration performed with separate cloud admin accounts, distinct from the person's everyday user account. Why: A PAW protects the device; separating accounts protects the credential, so a compromised user account cannot administer the tenant. Verify: Entra -> `Users`; confirm privileged roles are held by dedicated admin accounts, not day-to-day user accounts; run `ENTPAW-Report.ps1`. Implement: Create dedicated admin accounts for privileged operators; assign roles (via PIM eligibility) to those accounts, not to their user accounts.

2.5 PIM eligibility for the operated roles

Description: The privileged roles used from the PAW are onboarded to PIM as eligible (not standing), with an activation policy. Why: The PAW is the clean device; PIM makes the privilege itself just-in-time so it is time-bound and only activated from that device. Verify: Entra -> `Identity governance -> PIM -> Microsoft Entra roles -> Assignments`; confirm eligible assignments; run `ENTPAW-Validate.ps1`. Implement: Onboard the roles to PIM as eligible (see the Privileged Identity Management solution) before enforcing the PAW device filter.

2.6 Break-glass exclusion group

Description: A security group containing your two cloud-only break-glass accounts, excluded from the PAW device-filter enforcement policy. Why: If the device marking or compliance is misconfigured, break-glass accounts must still sign in and prevent a full lockout. Verify: Entra -> `Groups`; confirm a group (for example `CA Break-Glass Exclusion`) contains both break-glass accounts; run `ENTPAW-Validate.ps1`. Implement: Create/confirm `CA Break-Glass Exclusion` and add it to the Exclude tab of the device-filter policy.

2.7 A device-marking method for the CA device filter

Description: A chosen way to mark PAW devices so a Conditional Access device filter can recognise them — a device extension attribute (`extensionAttribute1–15`), a device category, or membership of a device group. Why: The device-filter rule matches on a device property; that property must be set on PAWs and only on PAWs. Verify: Entra -> `Devices`; confirm the chosen attribute/category is available and not already used for another purpose; run `ENTPAW-Discovery.ps1`. Implement: Choose one marker (this guide uses `extensionAttribute1 = PAW`), reserve it for PAWs, and set it with `ENTPAW-DeviceTag.ps1` (preview-first).

2.8 Pilot scope (admins and devices)

Description: A small set of pilot admins and their pilot PAWs to validate hardening, compliance, device-filter enforcement, and PIM before tenant-wide rollout. Why: The identity plane is high risk; a report-only pilot proves the control and the admin experience before it blocks anyone. Verify: Entra -> `Groups`; confirm the pilot user and device groups exist; run `ENTPAW-Validate.ps1`. Implement: Create `PAW Admins – Cloud Admin – Pilot` (users) and `PAW Devices – Admin Devices – Pilot` (devices) and populate them with the pilot admins and their PAWs.

Checklist

- Microsoft Intune with Windows enrolment — `ENTPAW-Discovery.ps1` *(verify licensing)*
- Entra ID P2 for privileged operators — *(verify licensing)*
- Dedicated PAW device per pilot admin
- Separate cloud admin accounts in use — `ENTPAW-Report.ps1`
- Operated roles onboarded to PIM (eligible) — `ENTPAW-Validate.ps1`
- `CA Break-Glass Exclusion` group contains both break-glass accounts
- Device marker chosen and reserved (e.g. `extensionAttribute1 = PAW`) — `ENTPAW-DeviceTag.ps1`
- `PAW Admins – Cloud Admin – Pilot` and `PAW Devices – Admin Devices – Pilot` created — `ENTPAW-Validate.ps1`

Global Requirements — Entra ID Solutions (category-level)

These requirements apply to every solution in the Entra ID Solutions category. They are published once at the category level so individual listings stay small. Confirm these before deploying any identity solution. Each entry: Description / Why / Verify / Implement-if-missing.

> *The identity plane is high risk. A mistake here breaks sign-in for everyone, so every change is staged and a break-glass account is kept ready before you touch anything.*

G1. Microsoft Entra ID tenant

Description: An active Microsoft Entra ID tenant. Why: It is the cloud identity backbone every other identity service builds on. Verify: Sign in to `https://entra.microsoft.com` as an administrator. Implement: Create a Microsoft 365 or Azure subscription, which provisions a tenant.

G2. Entra ID licensing (P1, P2 where noted)

Description: Microsoft Entra ID P1 (or P2 for risk-based and PIM features). Why: Hybrid features such as seamless sign-in, password writeback, and Conditional Access require P1+. Verify: M365 admin center -> `Billing -> Licenses`; confirm Entra ID P1/P2 (often bundled in M365 E3/E5 or EMS). Implement: Assign M365 E3/E5, EMS E3/E5, or standalone Entra ID P1/P2.

G3. Administrative roles

Description: Hybrid Identity Administrator and Global Administrator for the operator. Why: Configuring directory synchronization and authentication methods needs these elevated roles. Verify: Entra -> `Roles and administrators`; confirm `Hybrid Identity Administrator` (and a Global Administrator for the one-time first-sync consent). Implement: Assign `Hybrid Identity Administrator`; reserve `Global Administrator` for tenant-wide and first-sync changes.

G4. Break-glass (emergency access) accounts

Description: At least two cloud-only emergency access accounts, excluded from Conditional Access and MFA-broad policies. Why: If sync, federation, or an auth-method change locks out admins, break-glass

accounts get you back in. Verify: Entra -> `Users`; confirm two cloud-only accounts (`@onmicrosoft.com`) with strong stored credentials and documented use. Implement: Create two cloud-only Global Administrator accounts; exclude them from policies; store credentials securely and monitor sign-ins.

G5. Healthy on-premises Active Directory

Description: A functional AD forest/domain with healthy replication and DNS. Why: Synchronization reads from AD; replication or DNS faults corrupt or stall the sync. Verify: Run `dcdiag` and `repadmin /replsummary` on a domain controller with no errors; run `HYBID-Discovery.ps1`. Implement: Resolve AD replication, DNS, and time-sync issues before synchronizing.

G6. An Entra Connect host server

Description: A domain-joined Windows Server (2016+), patched, for Microsoft Entra Connect Sync (or a lightweight host with the Cloud Sync agent). Why: Connect Sync runs as a service on this host and must reach both AD and Entra ID. Verify: A supported, domain-joined server with TLS 1.2, .NET, and PowerShell available; run `HYBID-Discovery.ps1`. Implement: Provision a dedicated server (not a domain controller for production), patch it, and enable TLS 1.2.

G7. UPN / domain hygiene

Description: User principal names use a public, verified, routable domain (not `.local`). Why: A non-routable UPN suffix produces sign-in problems and `onmicrosoft.com` fallbacks in the cloud. Verify: Entra -> `Identity -> Settings -> Domain names` shows the public domain Verified; AD UPN suffixes match it; run `HYBID-Discovery.ps1`. Implement: Add and verify the public domain in Entra; add the matching UPN suffix in AD and update user UPNs.

G8. Network access to Microsoft cloud endpoints

Description: Outbound HTTPS (443) from the Connect host to Entra ID, plus required Microsoft 365 service URLs. Why: Synchronization, authentication-agent traffic, and tokens depend on these endpoints. Verify: From the Connect host, reach `https://login.microsoftonline.com` and the Microsoft 365 published URL/IP ranges. Implement: Allow the Microsoft 365 / Entra service URLs and IP ranges through the proxy/firewall.

The deployment model (all solutions): Assess -> Configure -> Pilot -> Validate -> Expand.

3. Implementation Guide — Privileged Access Workstation (PAW) for Cloud Administration

Follow these steps in order, in the Microsoft Intune admin center (`https://intune.microsoft.com`) and the Microsoft Entra admin center (`https://entra.microsoft.com`). The Conditional Access enforcement policy is created in **Report-only** first; you enforce only after the Testing Guide passes. Break-glass accounts (via `CA Break-Glass Exclusion`) are excluded from enforcement throughout.

> *Model: build and mark the hardened PAW, define compliance, create the device-filter enforcement policy in report-only, wire PIM, pilot, validate the report-only results, flip to enforce in stages, then*

expand. Every object uses `<Purpose> – <Scope> – <Stage>` and is reused by name in Testing and Troubleshooting.

Naming convention (create/verify these exact names)

Object	Name
Pilot admin (user) group	`PAW Admins – Cloud Admin – Pilot`
Pilot device group	`PAW Devices – Admin Devices – Pilot`
Break-glass exclusion group	`CA Break-Glass Exclusion`
Compliance policy	`Compliance – PAW – Pilot`
Security baseline profile	`Baseline – PAW Security – Pilot`
ASR profile	`ASR – PAW – Pilot`
Application-control policy	`AppControl – PAW – Pilot`
Device restrictions (isolation)	`Restrictions – PAW Isolation – Pilot`
Enforcement policy	`CA – Require PAW for Privileged Roles – Pilot (Report-Only)`
Device marker	`extensionAttribute1 = PAW`

Step 1 — Assess and record the starting state

1. Run `ENTPAW-Discovery.ps1` to inventory privileged roles and who holds them, existing device compliance policies, any Conditional Access device-filter policies, and the chosen device-marker attribute's current use. Keep the output as your before-state.

2. Confirm the operated roles are onboarded to PIM as eligible (Requirement 2.5) and that `CA Break-Glass Exclusion` exists. Do not proceed until break-glass exclusion is confirmed.

Step 2 — Create the pilot groups

1. Entra -> `Groups -> New group` -> Security -> `PAW Admins – Cloud Admin – Pilot`; add the pilot admins' dedicated admin accounts (not break-glass). Create.

2. `New group` -> Security -> `PAW Devices – Admin Devices – Pilot`; you will add the pilot PAW devices here (or use dynamic membership on the device marker). Create.

Step 3 — Enrol and build the hardened PAW in Intune

1. Enrol each pilot PAW into Intune (Autopilot or automatic enrolment). Keep the operator as a standard user (no local admin).

2. `Intune -> Endpoint security -> Security baselines`; create the Windows security baseline profile `Baseline – PAW Security – Pilot`; assign to `PAW Devices – Admin Devices – Pilot`.

3. `Endpoint security -> Attack surface reduction`; create `ASR – PAW – Pilot` with the ASR rules enabled (block credential stealing, Office child processes, untrusted executables, etc.); assign to the device group.

4. `Endpoint security -> Application control` (App Control for Business / WDAC); create `AppControl – PAW – Pilot` in an allow-list posture so only approved admin tooling runs; assign to the device group. *Verify current App Control feature availability and start in audit mode.*

5. `Devices -> Configuration`; create `Restrictions – PAW Isolation – Pilot` to remove/block general-purpose email and open web browsing (block consumer apps, restrict browsers to admin endpoints, disable personal mail profiles); assign to the device group.

Step 4 — Define what a PAW is (compliance policy)

1. `Intune -> Devices -> Compliance policies -> Create policy` (Windows); name `Compliance – PAW – Pilot`.

2. Require the hardened posture (firewall on, BitLocker on, Secure Boot, real-time protection, minimum OS, and where used a custom compliance script that checks the PAW marker/baseline). Set non-compliant action appropriately. Assign to `PAW Devices – Admin Devices – Pilot`. Create.

Step 5 — Mark the PAW devices for the device filter

1. Decide the marker: this guide uses `extensionAttribute1 = PAW` on the Entra device object.

2. Run `ENTPAW-DeviceTag.ps1` with the default `-WhatIf` to preview setting `extensionAttribute1 = PAW` on the pilot PAW devices; re-run without `-WhatIf` once confirmed. Only PAWs get this marker.

3. Confirm the marker in Entra -> `Devices -> (device) -> Properties`, and (if using dynamic membership) that `PAW Devices – Admin Devices – Pilot` picks up marked devices.

Step 6 — Create the Conditional Access device-filter policy (Report-only)

1. Entra -> `Protection -> Conditional Access -> Policies -> + New policy`; name `CA – Require PAW for Privileged Roles – Pilot (Report-Only)`.

• Assignments -> Users: include `PAW Admins – Cloud Admin – Pilot`; **exclude** `CA Break-Glass Exclusion`.

• Target resources: select the privileged/admin surfaces — `Microsoft Admin Portals` and the management apps (for example Windows Azure Service Management API / Microsoft Graph), or scope by directory role where supported.

• Conditions -> Filter for devices: set to **Include** devices where the rule is `device.extensionAttribute1 -eq "PAW"` — i.e. the policy applies when the device is NOT a PAW, so you can block; alternatively configure Grant to require a compliant device AND use the filter to require the PAW marker. Use the filter/grant combination that means "only a marked, compliant PAW is allowed".

• Grant: **Require device to be marked as compliant** (and, if desired, require multi-factor authentication). For non-PAW/non-compliant devices the effective result is Block.

• Enable policy: **Report-only**. Create.

1. Run `ENTPAW-Validate.ps1` to confirm the policy exists, is report-only, targets the pilot admins, uses the PAW device filter, and excludes break-glass.

Step 7 — Wire PIM activation from the PAW

1. Confirm the operated roles are eligible in PIM (Requirement 2.5) with an activation policy requiring MFA, justification, and (recommended) approval.

2. Have a pilot admin sign in from the PAW and activate the role in PIM. This is how privilege is exercised — just-in-time, from the clean device only.

3. Optionally require the sensitive authentication context (from the Identity Protection & Advanced Conditional Access solution) on activation for defence in depth.

Step 8 — Pilot and read the report-only results

1. Have pilot admins attempt privileged actions from the PAW (should succeed) and from a non-PAW device (report-only shows "would block"). Run `ENTPAW-Validate.ps1` and `ENTPAW-Report.ps1`.

2. Entra -> `Sign-in logs -> Report-only`; confirm `CA – Require PAW for Privileged Roles – Pilot (Report-Only)` would allow PAW sign-ins and would block non-PAW privileged sign-ins, and that **no break-glass account** shows an apply.

3. This is the pass/fail gate. Do not enforce until the report-only results match intent (see Testing Guide).

Step 9 — Flip to enforcement (staged)

1. Set the policy `Enable policy` to **On**, or use `ENTPAW-Set-CAState.ps1` (default `-WhatIf` preview, with a break-glass guard) to flip it from report-only to enabled after review.

2. Immediately confirm a pilot admin can still administer from the PAW and that a non-PAW privileged sign-in is now blocked; keep a break-glass account ready. Rename the policy dropping `(Report-Only)` once enforced.

3. If enforcement causes unexpected blocks, revert to report-only immediately (`ENTPAW-Set-CAState.ps1 -TargetState reportOnly`) and investigate.

Step 10 — Expand to production

1. Broaden `PAW Admins – Cloud Admin – Pilot` to all privileged operators and `PAW Devices – Admin Devices – Pilot` to all PAWs (keeping `CA Break-Glass Exclusion` excluded), re-validating in report-only for the wider scope before enforcing.

2. Move App Control from audit to enforced once tuning is complete; finalise isolation restrictions.

3. Stand up monitoring: run `ENTPAW-Report.ps1` on a schedule to catch any privileged sign-in attempted from a non-PAW device.

Order of operations

`Assess/discovery -> Pilot groups -> Build PAW (baseline/ASR/app control/isolation) -> Compliance policy -> Mark devices -> CA device-filter policy (report-only) -> PIM from PAW -> Read report-only -> Staged enforce -> Expand`

5. Testing Guide — Privileged Access Workstation (PAW) for Cloud Administration

Run after the pilot PAW and policy are configured in report-only (Implementation Step 8), again after the enforcement flip (Step 9), and after each expansion. Use `ENTPAW-Validate.ps1` for configuration state and `ENTPAW-Report.ps1` for privileged-access coverage.

Test 1 — PAW is hardened and compliant

Do: `Intune -> Devices -> (pilot PAW) -> Device compliance`; confirm `Compliance – PAW – Pilot` is Compliant and the baseline/ASR/app-control/isolation profiles show applied. Run `ENTPAW-Validate.ps1`. Expected: The pilot PAW is compliant, hardened, and shows email/web isolation applied; App Control is at least in audit with no unexpected blocks of admin tooling.

Test 2 — Device marker is set only on PAWs

Do: Entra -> `Devices`; confirm `extensionAttribute1 = PAW` on the pilot PAWs and on no other devices; run `ENTPAW-Validate.ps1`. Expected: Only PAWs carry the marker; the device group / device filter resolves to exactly the PAW set.

Test 3 — Enforcement policy exists, report-only, break-glass excluded

Do: Run `ENTPAW-Validate.ps1`. Expected: `CA – Require PAW for Privileged Roles – Pilot (Report-Only)` exists, is report-only, targets `PAW Admins – Cloud Admin – Pilot`, uses the PAW device filter, requires compliant device, and excludes `CA Break-Glass Exclusion`.

Test 4 — Privileged sign-in from the PAW would succeed

Do: A pilot admin signs in to a protected admin surface from the PAW; open the sign-in in `Sign-in logs -> Report-only`. Expected: The policy would grant (PAW + compliant); the admin can reach the admin portal / activate PIM from the PAW.

Test 5 — Privileged sign-in from a non-PAW would be blocked

Do: The same pilot admin attempts the protected admin surface from a general-purpose (non-PAW) device; review the report-only result. Expected: `CA – Require PAW for Privileged Roles – Pilot (Report-Only)` shows "Would block" for the non-PAW device.

Test 6 — PIM activation works from the PAW

Do: From the PAW, the pilot admin activates an eligible role in PIM (MFA + justification + approval if set). Expected: Activation succeeds from the PAW and grants the role for the configured window; the admin

never holds standing privilege.

Test 7 — Break-glass path is never blocked

Do: Confirm (report-only and after enforcement) a break-glass account can sign in with the device-filter policy not applying; run `ENTPAW-Validate.ps1`. Expected: Break-glass accounts are excluded and retain an unobstructed path in, even from a non-PAW device.

Test 8 — Non-PAW privileged access is visible in reporting

Do: Run `ENTPAW-Report.ps1` (KQL or Graph fallback). Expected: Any privileged sign-in attempted from a non-PAW device is listed, so gaps and policy exceptions are visible.

Test 9 — Enforcement matches the report-only prediction

Do: After flipping to On (Step 9), repeat Tests 4 and 5 against the real `Conditional Access` result. Expected: PAW sign-ins succeed; non-PAW privileged sign-ins are blocked; no unexpected admin is locked out.

Pass/fail gate

Gate	Requirement
Pilot pass	Tests 1-7 pass in report-only; PAW allowed, non-PAW would-block, break-glass excluded
Enforce pass	Test 9 passes; a non-PAW privileged sign-in is blocked and PAW admins are unaffected
Expand pass	Tests re-pass at the wider scope in report-only before enforcing tenant-wide; App Control moved to enforced after tuning

6. Troubleshooting Guide — Privileged Access Workstation (PAW) for Cloud Administration

Use `ENTPAW-Validate.ps1` / `ENTPAW-Discovery.ps1` for current configuration state, `ENTPAW-Report.ps1` for privileged-access coverage, `ENTPAW-Set-CAState.ps1` (default `-WhatIf`, with a break-glass guard) to flip the policy back to report-only fast, and `ENTPAW-DeviceTag.ps1` to fix device markers.

A. PAW not recognised by the device filter

Symptom	Cause	Remediation
PAW admin "would block" even from the PAW	Device marker not set, or set on the wrong device object	Confirm `extensionAttribute1 = PAW` on the correct Entra device object; set with `ENTPAW-DeviceTag.ps1`; allow directory propagation
Device filter matches the wrong devices	Marker reused elsewhere, or filter rule typo	Reserve the marker for PAWs only; confirm the rule is exactly `device.extensionAttribute1 -eq "PAW"`; run `ENTPAW-Validate.ps1`
Filter change not taking effect	Token still cached from before the change	Sign out/in on the PAW to get a fresh evaluation; re-check `Sign-in logs -> Report-only`

B. Compliance / hardening problems

Symptom	Cause	Remediation
PAW shows non-compliant	Baseline/BitLocker/Secure Boot/firewall requirement not met, or policy still applying	Open `Intune -> Devices -> (PAW) -> Device compliance`; remediate the failing setting; wait for the next check-in
Admin tooling blocked on the PAW	App Control allow-list too tight	Keep App Control in audit; add the required admin tools to the allow-list; only then move to enforced
Admin can still read email / browse freely	Isolation restrictions not assigned or not applied	Confirm `Restrictions – PAW Isolation – Pilot` is assigned to `PAW Devices – Admin Devices – Pilot` and applied; re-sync the device

C. Break-glass / lockout risk

• Confirm `CA Break-Glass Exclusion` (both cloud-only break-glass accounts) is on the Exclude tab of `CA – Require PAW for Privileged Roles – Pilot`; run `ENTPAW-Validate.ps1`. The `ENTPAW-Set-CAState.ps1` guard refuses to enable a policy that does not exclude break-glass.

• If the device filter locks out administrators, sign in with a break-glass account (from any device), set the policy to report-only, and investigate. Never remove the break-glass exclusion.

D. Conditional Access enforcement issues

Symptom	Cause	Remediation
Non-PAW privileged sign-in NOT blocked after enforce	Policy still report-only, or target resources too narrow	Confirm state is enabled (`ENTPAW-Validate.ps1`); confirm the admin surface (admin portals / management API) is targeted
Legitimate PAW admin blocked after enforce	Compliance flapping, or grant requires a method the admin lacks	Confirm compliance is stable; confirm required MFA/method is registered; revert to report-only if needed and re-read
Policy applies to non-admin sign-ins	User scope too broad	Scope Users to `PAW Admins – Cloud Admin – Pilot` and the correct admin resources only

E. PIM activation from the PAW

Symptom	Cause	Remediation
Cannot activate a role from the PAW	Role not eligible, or activation blocked by policy	Confirm an eligible assignment exists in PIM; check the activation policy (MFA/approval); see the PIM solution
Activation succeeds but admin portal still blocked	Device filter evaluated the sign-in as non-PAW	Fix the device marker/compliance (Section A/B); the PAW must be recognised for the session

F. Licensing / feature not visible

- If PIM or device filters are not available, confirm Entra ID P2 (PIM) and Conditional Access (P1+) licensing; if App Control or a baseline is missing, confirm Intune licensing and enrolment. Run `ENTPAW-Discovery.ps1`. *Verify current availability in your tenant.*

G. Diagnostics quick reference

```
Connect-MgGraph -Scopes 'Policy.Read.All','Device.Read.All','DeviceManagementConfiguration.Read.All'
# Conditional Access device-filter policies and state
Get-MgIdentityConditionalAccessPolicy -All | Where-Object { $_.Conditions.Devices } | Select-Object Displa
# Device marker check
Invoke-MgGraphRequest -Method GET -Uri "/v1.0/devices?`$filter=extensionAttributes/extensionAttribute1 eq
# Intune compliance policies
Invoke-MgGraphRequest -Method GET -Uri '/v1.0/deviceManagement/deviceCompliancePolicies'
```

H. When to escalate

If the PAW is compliant and correctly marked, break-glass is excluded, PIM eligibility is in place, and privileged sign-ins still evaluate incorrectly after a clean report-only read, capture `ENTPAW-Report.ps1` output and the affected sign-in's report-only detail and open a Microsoft support case.

7. Best Practices — Privileged Access Workstation (PAW) for Cloud Administration

• Enforce clean source, both device and credential. A PAW protects the device; separate cloud admin accounts protect the credential. Use both — a dedicated PAW and dedicated admin accounts held eligibly in PIM — not one without the other.

• Keep the PAW truly dedicated. No general-purpose email, no open web browsing, no personal apps. The moment a PAW does double duty as a productivity machine, it stops being a PAW. Give admins a separate device for everyday work.

• Always start report-only. Create the device-filter enforcement policy in report-only, read the "would allow / would block" data, and confirm PAW sign-ins pass and non-PAW privileged sign-ins would block before you flip to On.

• Keep break-glass out of enforcement. Exclude `CA Break-Glass Exclusion` from the device-filter policy, always — a marking or compliance mistake must never lock out every administrator. Protect break-glass with strong stored credentials and sign-in alerts.

• Start App Control in audit, then enforce. Application allow-listing is powerful and disruptive; run it in audit on the pilot, tune the allow-list against real admin tooling, then move to enforced during expansion.

• Reserve the device marker for PAWs only. Whatever marks a PAW (extension attribute, category, or group) must be set only on PAWs and never reused for another purpose, or the device filter will admit the wrong devices. Set it with the preview-first tagging script.

• Grant privilege just-in-time from the PAW. Hold admin roles eligible in PIM and activate them from the PAW with MFA, justification, and approval — so privilege is time-bound and only ever exercised from the clean device.

• Layer step-up for the highest-value actions. Optionally require the sensitive authentication context (from the Identity Protection & Advanced Conditional Access solution) on PIM activation for defence in depth.

• Name every object consistently. Use `<Purpose> – <Scope> – <Stage>` for groups, profiles, compliance, and policies so audits, rollbacks, and expansion stay repeatable. Drop `(Report-Only)` only when actually enforced.

• Monitor for non-PAW privileged access. Run `ENTPAW-Report.ps1` on a schedule so any attempt to use privileged access from a non-PAW device is surfaced and closed.

• Verify licensing and preview facts. Intune and Entra ID P2 are required; App Control and some device-filter behaviours may have platform/preview constraints — verify current availability in your tenant rather than assuming.

Where to go next (adjacent catalog areas)

• **Privileged Identity Management (PIM)** — make the roles operated from the PAW just-in-time and approval-gated; this solution assumes it.

• **Entra Identity Protection & Advanced Conditional Access** — add risk-based access and require a step-up authentication context on PIM activation from the PAW.

• **Conditional Access baseline** — the require-MFA / block-legacy-auth foundation the device-filter policy layers on.

• **Intune endpoint security** (security baselines, ASR, App Control, compliance) — the device-hardening program the PAW build draws on; deepen it for the wider fleet.

• **Passwordless / passkey (FIDO2) rollout** — register phishing-resistant sign-in for the PAW admin accounts.

8. Deliverables Summary — Privileged Access Workstation (PAW) for Cloud Administration

Documentation

Document	Purpose
Executive Summary	Business case and what is in the box
1. Solution Overview	What a PAW is; how hardening, isolation, device filters, and PIM fit together; benefits and limitations
2. Requirements Guide	Solution-specific prerequisites with Verify / Implement-if-missing (Intune, P2 flagged to verify)
Global Requirements (Entra ID Solutions)	Category-wide prerequisites, published once
3. Implementation Guide	Exact, ordered Intune + Entra steps — build, mark, enforce report-only first, staged enforcement, break-glass excluded
5. Testing Guide	Validation procedures with pass/fail gates
6. Troubleshooting Guide	Field issues and remediation
7. Best Practices	Field-proven recommendations and where to go next

PowerShell scripts (and KQL)

Script	What it does
`ENTPAW-Discovery.ps1`	Read-only inventory of privileged roles/holders, device compliance policies, Conditional Access device-filter policies, and current use of the device-marker attribute (Microsoft Graph)
`ENTPAW-Validate.ps1`	Confirms the PAW compliance policy, device marker, and the device-filter enforcement policy are in place, report-only, pilot-scoped, and break-glass excluded; checks PIM eligibility

Script	What it does
`ENTPAW-Report.ps1`	Privileged-access-from-non-PAW report — surfaces admin sign-ins from unmarked/non-compliant devices, plus coverage gaps (KQL against exported sign-in logs with a Graph fallback)
`ENTPAW-Set-CAState.ps1`	Safe change script (default `-WhatIf`, break-glass guard); flips the PAW device-filter policy between report-only and enabled for staged enforcement/rollback
`ENTPAW-DeviceTag.ps1`	Safe change script (default `-WhatIf`); sets the `extensionAttribute1 = PAW` marker on named pilot PAW devices so the Conditional Access device filter recognises them

What the buyer receives

- This implementation guide as a branded Word document and PDF.
- All five PowerShell scripts (with embedded KQL) in a single ZIP.
- Delivered as a Complete Solution Package (PDF + Word + scripts).
- A repeatable process following the standard model: Assess -> Configure -> Pilot -> Validate -> Expand.

Outcome

Administrators working from clean, isolated, hardened workstations — with privileged access impossible from a general-purpose or compromised device, enforced by Conditional Access device filters and granted just-in-time by PIM — proven on a pilot before you enforce.

Appendix A — PowerShell Scripts

Included in the accompanying ZIP. Each script's header documents full usage.

ENTPAW-DeviceTag.ps1

Purpose: Marks a device as a PAW by setting an Entra device extension attribute (default extensionAttribute1 = PAW) so the Conditional Access device filter can recognise it. Runs in -WhatIf (preview) mode by default and only touches the devices you name, so the marker stays reserved for genuine PAWs. Can also clear the marker (-Remove) to decommission a PAW. HOW TO RUN Preview (default): powershell -ExecutionPolicy Bypass -File .\ENTPAW-DeviceTag.ps1 ` -DeviceNames "PAW-ADM-01","PAW-ADM-02" Apply: add -WhatIf:$false after reviewing the preview. Remove marker: add -Remove (also -WhatIf by default). Requires the Microsoft Graph PowerShell SDK. Scope: Device.ReadWrite.All. EXPECTED RESULTS A preview (or applied change) setting/clearing the marker on exactly the named devices. Re-run ENTPAW-Validate.ps1 afterward to confirm the device filter resolves to the PAW set. .NOTES White-label — Entra ID Solutions. Changes a device attribute — preview first, reserve the marker for PAWs only. > [CmdletBinding(SupportsShouldProcess=$true, ConfirmImpact='Medium')] param([Parameter(Mandatory=$true)][string[]]$DeviceNames, [string]$MarkerAttribute = 'extensionAttribute1', [string]$MarkerValue = 'PAW', [switch]$Remove) if (-not (Get-Module -ListAvailable -Name Microsoft.Graph.Authentication)) { Install-Module Microsoft.Graph -Scope CurrentUser -Force -AllowClobber } Import-Module Microsoft.Graph.Authentication -ErrorAction Stop Connect-MgGraph -Scopes 'Device.ReadWrite.All' -NoWelcome $val = if ($Remove) { $null } else { $MarkerValue } Write-Host "=== ENTPAW DeviceTag — set $MarkerAttribute=$(if($Remove){'<null>'}else{$MarkerValue}) on $($DeviceNames.Count) device(s) ===" -ForegroundColor Cyan

How to run: Preview (default): powershell -ExecutionPolicy Bypass -File .\ENTPAW-DeviceTag.ps1 ` -DeviceNames "PAW-ADM-01","PAW-ADM-02" Apply: add -WhatIf:$false after reviewing the preview. Remove marker: add -Remove (also -WhatIf by default). Requires the Microsoft Graph PowerShell SDK. Scope: Device.ReadWrite.All. EXPECTED RESULTS A preview (or applied change) setting/clearing the marker on exactly the named devices. Re-run ENTPAW-Validate.ps1 afterward to confirm the device filter resolves to the PAW set. .NOTES White-label — Entra ID Solutions. Changes a device attribute — preview first, reserve the marker for PAWs only. > [CmdletBinding(SupportsShouldProcess=$true, ConfirmImpact='Medium')] param([Parameter(Mandatory=$true)][string[]]$DeviceNames, [string]$MarkerAttribute = 'extensionAttribute1', [string]$MarkerValue = 'PAW', [switch]$Remove) if (-not (Get-Module -ListAvailable -Name Microsoft.Graph.Authentication)) { Install-Module Microsoft.Graph -Scope CurrentUser -Force -AllowClobber } Import-Module Microsoft.Graph.Authentication -ErrorAction Stop Connect-MgGraph -Scopes 'Device.ReadWrite.All' -NoWelcome $val = if ($Remove) { $null } else { $MarkerValue } Write-Host "=== ENTPAW DeviceTag — set $MarkerAttribute=$(if($Remove){'<null>'}else{$MarkerValue}) on $($DeviceNames.Count) device(s) ===" -ForegroundColor Cyan

ENTPAW-Discovery.ps1

Purpose: Records the before-state for a PAW rollout: who holds privileged directory roles, existing Intune device compliance policies, any Conditional Access policies that already use a device condition/filter, and whether the chosen device-marker attribute (extensionAttribute1) is already in use. This is the baseline you keep for rollback. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\ENTPAW-Discovery.ps1

Requires the Microsoft Graph PowerShell SDK. Read-only scopes: RoleManagement.Read.Directory, Policy.Read.All, Device.Read.All, DeviceManagementConfiguration.Read.All, User.Read.All. EXPECTED RESULTS A printed inventory: privileged role holders, compliance policies, CA device-filter policies, and current devices already tagged with the PAW marker. .NOTES White-label — Entra ID Solutions. Read-only against Graph. Verify Intune + Entra ID P2 availability. > [CmdletBinding()] param([string]$MarkerAttribute = 'extensionAttribute1', [string]$MarkerValue = 'PAW') if (-not (Get-Module -ListAvailable -Name Microsoft.Graph.Authentication)) { Install-Module Microsoft.Graph -Scope CurrentUser -Force -AllowClobber } Import-Module Microsoft.Graph.Authentication -ErrorAction Stop Connect-MgGraph -Scopes 'RoleManagement.Read.Directory','Policy.Read.All','Device.Read.All','Device ManagementConfiguration.Read.All','User.Read.All' -NoWelcome

How to run: powershell -ExecutionPolicy Bypass -File .\ENTPAW-Discovery.ps1 Requires the Microsoft Graph PowerShell SDK. Read-only scopes: RoleManagement.Read.Directory, Policy.Read.All, Device.Read.All, DeviceManagementConfiguration.Read.All, User.Read.All. EXPECTED RESULTS A printed inventory: privileged role holders, compliance policies, CA device-filter policies, and current devices already tagged with the PAW marker. .NOTES White-label — Entra ID Solutions. Read-only against Graph. Verify Intune + Entra ID P2 availability. > [CmdletBinding()] param([string]$MarkerAttribute = 'extensionAttribute1', [string]$MarkerValue = 'PAW') if (-not (Get-Module -ListAvailable -Name Microsoft.Graph.Authentication)) { Install-Module Microsoft.Graph -Scope CurrentUser -Force -AllowClobber } Import-Module Microsoft.Graph.Authentication -ErrorAction Stop Connect-MgGraph -Scopes 'RoleManagement.Read.Directory','Policy.Read.All','Device.Read.All','DeviceManagementConfig uration.Read.All','User.Read.All' -NoWelcome

ENTPAW-Report.ps1

Purpose: The core monitoring report: finds administrative sign-ins that came from a device that is NOT a compliant PAW, so exceptions and gaps are visible before and after enforcement. If Entra sign-in logs are exported to a Log Analytics / Microsoft Sentinel workspace, it runs the embedded KQL there; otherwise it falls back to a read-only Microsoft Graph query of recent sign-ins to the admin surfaces and flags those from non-compliant devices. HOW TO RUN KQL mode: powershell -ExecutionPolicy Bypass -File .\ENTPAW-Report.ps1 -WorkspaceId "<LA workspace GUID>" (requires Az.OperationalInsights and reader access to the workspace) Graph mode: powershell -ExecutionPolicy Bypass -File .\ENTPAW-Report.ps1 (Microsoft Graph SDK; read-only: AuditLog.Read.All, Directory.Read.All) EXPECTED RESULTS A list of privileged sign-ins from non-PAW/non-compliant devices. Read-only — no changes made. Verify sign-in log export exists for KQL mode. .NOTES White-label — Entra ID Solutions. Read-only. KQL requires SigninLogs exported to a workspace. > [CmdletBinding()] param([string]$WorkspaceId, [int]$Days = 7)

How to run: KQL mode: powershell -ExecutionPolicy Bypass -File .\ENTPAW-Report.ps1 -WorkspaceId "<LA workspace GUID>" (requires Az.OperationalInsights and reader access to the workspace) Graph mode: powershell -ExecutionPolicy Bypass -File .\ENTPAW-Report.ps1 (Microsoft Graph SDK; read-only: AuditLog.Read.All, Directory.Read.All) EXPECTED RESULTS A list of privileged sign-ins from non-PAW/non-compliant devices. Read-only — no changes made. Verify sign-in log export exists for KQL mode. .NOTES White-label — Entra ID Solutions. Read-only. KQL requires SigninLogs exported to a workspace. > [CmdletBinding()] param([string]$WorkspaceId, [int]$Days = 7)

ENTPAW-Set-CAState.ps1

Purpose: Performs the staged-enforcement (and rollback) step for the PAW device-filter policy: moves the single, named Conditional Access policy from report-only to enabled — or back — after the report-only results are clean. Runs in -WhatIf (preview) mode by default. As a safety guard it refuses to enable a policy that does NOT exclude the named break-glass group, so a device-filter mistake can never lock out break-glass accounts. HOW TO RUN Preview (default): powershell -ExecutionPolicy Bypass -File .\ENTPAW-Set-CAState.ps1 `-PolicyName "CA – Require PAW for Privileged Roles – Pilot (Report-Only)" -TargetState enabled` -BreakGlassGroupName "CA Break-Glass Exclusion" Apply: add -WhatIf:$false to the same command after reviewing the preview. Rollback: set -TargetState reportOnly to move the policy back to report-only. Requires the Microsoft Graph PowerShell SDK. Scope: Policy.ReadWrite.ConditionalAccess, Group.Read.All. EXPECTED RESULTS A preview (or applied change) of the policy state; the break-glass guard blocks enabling a policy that does not exclude break-glass. Re-run ENTPAW-Validate.ps1 afterward and watch Sign-in logs. .NOTES White-label — Entra ID Solutions. Changes a Conditional Access policy state — preview first, keep break-glass ready. > [CmdletBinding(SupportsShouldProcess=$true, ConfirmImpact='High')] param([Parameter(Mandatory=$true)][string]$PolicyName, [Parameter(Mandatory=$true)][ValidateSet('enabled','reportOnly')][string]$TargetState, [string]$BreakGlassGroupName = 'CA Break-Glass Exclusion') if (-not (Get-Module -ListAvailable -Name Microsoft.Graph.Authentication)) { Install-Module Microsoft.Graph -Scope CurrentUser -Force -AllowClobber } Import-Module Microsoft.Graph.Authentication -ErrorAction Stop Connect-MgGraph -Scopes 'Policy.ReadWrite.ConditionalAccess','Group.Read.All' -NoWelcome Write-Host "=== ENTPAW Set-CAState — '$PolicyName' -> $TargetState ===" -ForegroundColor Cyan

How to run: Preview (default): powershell -ExecutionPolicy Bypass -File .\ENTPAW-Set-CAState.ps1 `-PolicyName "CA – Require PAW for Privileged Roles – Pilot (Report-Only)" -TargetState enabled` -BreakGlassGroupName "CA Break-Glass Exclusion" Apply: add -WhatIf:$false to the same command after reviewing the preview. Rollback: set -TargetState reportOnly to move the policy back to report-only. Requires the Microsoft Graph PowerShell SDK. Scope: Policy.ReadWrite.ConditionalAccess, Group.Read.All. EXPECTED RESULTS A preview (or applied change) of the policy state; the break-glass guard blocks enabling a policy that does not exclude break-glass. Re-run ENTPAW-Validate.ps1 afterward and watch Sign-in logs. .NOTES White-label — Entra ID Solutions. Changes a Conditional Access policy state — preview first, keep break-glass ready. > [CmdletBinding(SupportsShouldProcess=$true, ConfirmImpact='High')] param([Parameter(Mandatory=$true)][string]$PolicyName, [Parameter(Mandatory=$true)][ValidateSet('enabled','reportOnly')][string]$TargetState, [string]$BreakGlassGroupName = 'CA Break-Glass Exclusion') if (-not (Get-Module -ListAvailable -Name Microsoft.Graph.Authentication)) { Install-Module Microsoft.Graph -Scope CurrentUser -Force -AllowClobber } Import-Module Microsoft.Graph.Authentication -ErrorAction Stop Connect-MgGraph -Scopes 'Policy.ReadWrite.ConditionalAccess','Group.Read.All' -NoWelcome Write-Host "=== ENTPAW Set-CAState — '$PolicyName' -> $TargetState ===" -ForegroundColor Cyan

ENTPAW-Validate.ps1

Purpose: Validates the PAW pilot before enforcement: the PAW compliance policy exists, the pilot devices carry the PAW marker, and the device-filter Conditional Access policy exists, is report-only, targets the pilot admins, requires a compliant device, uses the PAW filter, and excludes the break-glass group. Also confirms the pilot admins hold eligible (not standing) roles in PIM. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\ENTPAW-Validate.ps1 `-PolicyName "CA – Require PAW for Privileged Roles – Pilot (Report-Only)"` -PilotAdminGroup "PAW Admins – Cloud Admin –

Pilot" -BreakGlassGroupName "CA Break-Glass Exclusion" Requires the Microsoft Graph PowerShell SDK. Read-only scopes: Policy.Read.All, Group.Read.All, Device.Read.All, DeviceManagementConfiguration.Read.All, RoleManagement.Read.Directory. EXPECTED RESULTS PASS/WARN lines for compliance policy, device marker, the device-filter policy, and PIM eligibility. Any WARN is a gate failure to fix before flipping to enforcement. .NOTES White-label — Entra ID Solutions. Read-only against Graph. > [CmdletBinding()] param([string]$PolicyName = 'CA – Require PAW for Privileged Roles – Pilot (Report-Only)', [string]$PilotAdminGroup = 'PAW Admins – Cloud Admin – Pilot', [string]$BreakGlassGroupName = 'CA Break-Glass Exclusion', [string]$CompliancePolicyName = 'Compliance – PAW – Pilot', [string]$MarkerAttribute = 'extensionAttribute1', [string]$MarkerValue = 'PAW') if (-not (Get-Module -ListAvailable -Name Microsoft.Graph.Authentication)) { Install-Module Microsoft.Graph -Scope CurrentUser -Force -AllowClobber } Import-Module Microsoft.Graph.Authentication -ErrorAction Stop Connect-MgGraph -Scopes 'Policy.Read.All','Group.Read.All','Device.Read.All','DeviceManagement Configuration.Read.All','RoleManagement.Read.Directory' -NoWelcome Write-Host "n=== ENTPAW — pilot validation ===" -ForegroundColor Cyan

How to run: powershell -ExecutionPolicy Bypass -File .\ENTPAW-Validate.ps1 -PolicyName "CA – Require PAW for Privileged Roles – Pilot (Report-Only)" -PilotAdminGroup "PAW Admins – Cloud Admin – Pilot" -BreakGlassGroupName "CA Break-Glass Exclusion" Requires the Microsoft Graph PowerShell SDK. Read-only scopes: Policy.Read.All, Group.Read.All, Device.Read.All, DeviceManagementConfiguration.Read.All, RoleManagement.Read.Directory. EXPECTED RESULTS PASS/WARN lines for compliance policy, device marker, the device-filter policy, and PIM eligibility. Any WARN is a gate failure to fix before flipping to enforcement. .NOTES White-label — Entra ID Solutions. Read-only against Graph. > [CmdletBinding()] param([string]$PolicyName = 'CA – Require PAW for Privileged Roles – Pilot (Report-Only)', [string]$PilotAdminGroup = 'PAW Admins – Cloud Admin – Pilot', [string]$BreakGlassGroupName = 'CA Break-Glass Exclusion', [string]$CompliancePolicyName = 'Compliance – PAW – Pilot', [string]$MarkerAttribute = 'extensionAttribute1', [string]$MarkerValue = 'PAW') if (-not (Get-Module -ListAvailable -Name Microsoft.Graph.Authentication)) { Install-Module Microsoft.Graph -Scope CurrentUser -Force -AllowClobber } Import-Module Microsoft.Graph.Authentication -ErrorAction Stop Connect-MgGraph -Scopes 'Policy.Read.All','Group.Read.All','Device.Read.All','DeviceManagement Configuration.Read.All','RoleManagement.Read.Directory' -NoWelcome Write-Host "n=== ENTPAW — pilot validation ===" -ForegroundColor Cyan